

UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI



Act#
ISO 27001



Carrera:
ITI



Asignatura:
CNO V Seguridad Informática



Salazar Hernández Pablo de Jesús - 171580

Cavazos Zacarías Rodolfo – 178823

Nieto Diaz de Leon Jair de Jesus – 171676

Gutiérrez Hernández Rodolfo – 179598

Morquecho Medina Eduardo Gabriel – 175805

Bustamante Rocha Cristopher Leonardo - 173754



Mtro. Servando López Contreras



28/02/2026



1.- Alcance

1.1 Descripción de la Organización

Dell Technologies Inc. es una corporación multinacional de tecnología fundada en 1984 por Michael Dell, con sede en Round Rock, Texas, Estados Unidos. Es uno de los proveedores de soluciones tecnológicas más grandes del mundo, con presencia en más de 180 países y una plantilla que supera los 100,000 empleados a nivel global.

Giro: Diseño, fabricación, comercialización y soporte de productos y servicios tecnológicos de clase empresarial.

Tamaño: Corporación multinacional de gran escala (Fortune 500). Ingresos anuales superiores a USD 90,000 millones.

Servicios principales: Hardware (servidores, almacenamiento, redes), soluciones de nube (Dell APEX), seguridad gestionada (Dell SecureWorks), servicios de soporte técnico y consultoría.

Clientes: Corporativos globales, gobiernos, instituciones educativas, PYMES y consumidores finales.

Procesos críticos: Desarrollo de software embebido y firmware, cadena de suministro de hardware, atención a clientes empresariales y operación de centros de datos.

Entorno tecnológico: Centros de datos propios (Round Rock, Dublin, Chengdu), plataformas híbridas en nube, ecosistemas DevOps con Kubernetes, pipelines CI/CD, repositorios Git y herramientas de análisis estático de código.

1.2 Misión, Visión y Valores

Misión

Impulsar el progreso humano mediante la tecnología, proporcionando a sus clientes —desde usuarios individuales hasta grandes corporaciones y gobiernos— los productos, soluciones y servicios que les permitan alcanzar sus objetivos de manera eficiente, segura y escalable.

Visión

Ser la empresa de tecnología de infraestructura esencial más confiable del mundo, donde la innovación, la seguridad de la información y la excelencia operativa sean los pilares que sostengan la transformación digital de sus clientes y socios de negocio.



Valores Organizacionales

- Integridad: Actuar con honestidad y transparencia en cada decisión de negocio.
- Innovación: Fomentar el desarrollo de soluciones que generen valor real.
- Responsabilidad: Asumir el compromiso con clientes, empleados y la sociedad.
- Seguridad: Proteger la información como activo estratégico fundamental.
- Excelencia operativa: Mantener estándares de calidad y desempeño de clase mundial.

Objetivos Organizacionales del SGSI

- Salvaguardar la confidencialidad, integridad y disponibilidad de los activos de información.
- Garantizar la alineación continua con ISO/IEC 27001:2022, RGPD y legislaciones locales de protección de datos.
- Identificar, evaluar y tratar sistemáticamente las amenazas de seguridad que puedan impactar las operaciones.
- Promover una cultura de seguridad compartida en todos los niveles jerárquicos.
- Mejorar continuamente la eficacia del SGSI mediante auditorías internas y revisiones por la dirección.

1.3 Estructura Organizacional

Dell Technologies opera bajo una estructura funcional-matricial. Las principales áreas funcionales son: Ingeniería de Producto (Engineering & Product), Operaciones y Cadena de Suministro, Tecnologías de la Información (IT Global), Seguridad de la Información (CISO Office), Ventas y Marketing Global, Servicios al Cliente (Customer Support), y Legal & Cumplimiento Normativo.



1.4 Área, Proceso y Actividad bajo ISO 27001

Nivel	Descripción
Dirección	Ingeniería de Producto y Desarrollo de Software
Área	DevSecOps & Platform Engineering
Proceso	Ciclo de Vida de Desarrollo Seguro de Software (S-SDLC)
Actividad	Gestión segura de repositorios de código fuente, pipelines CI/CD, control de acceso a entornos DevOps y protección de propiedad intelectual de firmware

1.5 Justificación de la Intervención

El área de DevSecOps & Platform Engineering es la más crítica para la implementación prioritaria del SGSI por las siguientes razones:

- Concentración de activos de alto valor: Los repositorios de código fuente contienen la propiedad intelectual más valiosa de Dell (firmware de PowerEdge, iDRAC, OpenManage).



- Alto riesgo de acceso no autorizado: Los pipelines CI/CD tienen acceso directo a entornos de producción, lo que convierte una brecha en este proceso en un vector de ataque de alto impacto.
- Superficie de ataque amplia: La integración de herramientas de terceros (GitHub, Jenkins, SonarQube, Artifactory) expone a Dell a vulnerabilidades en la cadena de suministro de software.
- Regulaciones aplicables: El RGPD y la Ley de Resiliencia Cibernética de la UE exigen controles formales sobre el desarrollo seguro de software.
- Precedente de incidentes: El sector tecnológico registra un incremento del 42% en ataques a cadenas de suministro de software (SolarWinds, Log4j), lo que eleva la exposición de Dell como fabricante global.

1.6 Alcance, Exclusiones, Supuestos y Restricciones

Alcance formal del SGSI

El presente SGSI aplica a los procesos, sistemas de información, infraestructura tecnológica y activos de datos relacionados con el diseño, desarrollo y despliegue de software en el área de DevSecOps & Platform Engineering de Dell Technologies, incluyendo sus repositorios Git corporativos, pipelines CI/CD, entornos de pruebas y herramientas de análisis de seguridad de código.

Exclusiones

- Subsidiarias con SGSI certificado de forma independiente (Dell Boomi, VMware).
- Operaciones de manufactura física de hardware en plantas de ensamblaje.
- Sistemas de ventas y CRM no gestionados por el área de ingeniería.

Supuestos

- La alta dirección otorga el presupuesto y apoyo necesario para la implementación del SGSI.
- El personal del área DevSecOps tiene disponibilidad para capacitación y cumplimiento de controles.

Restricciones

- El plazo de certificación es de 18 meses a partir de la aprobación del proyecto.
- El alcance no incluye centros de datos externos gestionados por proveedores de nube pública.



Activos

1. Servidores de Rack: Unidades modulares para centros de datos.
2. Servidores Blade: Servidores delgados que comparten chasis y alimentación.
3. Workstations de Torre: Equipos de alto rendimiento para renderizado y CAD.
4. Workstations Móviles: Laptops de gama profesional con GPUs certificadas.
5. Nodos de Cómputo de IA: Servidores especializados con aceleradores tensoriales.
6. Máquinas Virtuales (VMs): Instancias lógicas de servidores.
7. Contenedores (Docker/Kubernetes): Unidades de software aisladas para microservicios.
8. TPU pod(Tensor Processing Units)/instancia de tpu: Hardware para aprendizaje profundo.
9. Mainframes: Computadoras de gran escala para transacciones críticas.
10. Microcontroladores (MCU): Chips para control de hardware específico.
11. FPGAs: Chips programables para aceleración de tareas específicas.
12. Thin Clients: Terminales ligeras que procesan en el servidor.
13. Sistemas Operativos de Servidor: Licencias de Windows Server, Red Hat, etc.
14. Clústeres de HPC: Conjuntos de nodos trabajando como una sola computadora.
15. Coprocesadores de Cifrado: Hardware dedicado a la criptografía.
16. Arreglos Flash (All-Flash Arrays): Sistemas de almacenamiento sin partes móviles.
17. NAS (Network Attached Storage): Almacenamiento conectado a la red local.
18. SAN (Storage Area Network): Redes dedicadas de almacenamiento.
19. Librerías de Cintas (LTO): Para respaldo físico a largo plazo.
20. Bases de Datos SQL: Estructuras lógicas de datos (tablas).
21. Data Lakes: Repositorios de datos no estructurados.
22. Objetos de Almacenamiento en la Nube (Buckets): Espacio virtualizado.
23. Tarjetas SD/MicroSD: Para almacenamiento en dispositivos de borde.
24. Almacenamiento en Memoria (In-Memory DB): Datos que residen en la RAM.
25. Dispositivos de Respaldo Inmutable: Hardware que impide borrar datos.
26. Switches Core: Conmutadores de alta capacidad en el núcleo de la red.
27. Switches de Acceso: Conectan los dispositivos finales a la red.
28. Routers de Borde: Gestionan la salida a Internet y VPNs.
29. Firewalls de Próxima Generación (NGFW): Filtran el tráfico de red.
30. Puntos de Acceso Wi-Fi (AP): Antenas para transmisión inalámbrica.
31. Controladoras de Red Inalámbrica (WLC): Gestionan múltiples APs.
32. Transceptores de Fibra Óptica (SFP+): Convierten luz en electricidad.
33. Balanceadores de Carga: Distribuyen el tráfico entre servidores.



- 34. Pasarelas VoIP: Transmiten voz sobre protocolos de datos.
- 35. Tarjetas de Red (NIC): Interfaces físicas en servidores.
- 36. Puentes de Red (Bridges): Conectan segmentos de red distintos.
- 37. Concentradores VPN: Permiten transmisiones seguras remotas.
- 38. Proxy Servers: Activos que transmiten peticiones en nombre del usuario.
- 39. Módems DSL/Fibra: Modulan la señal para transmisión externa.
- 40. DNS Servers: Transmiten la resolución de nombres a IPs.
- 41. SD-WAN Appliances: Gestión inteligente de la transmisión WAN.
- 42. Switches de Canal de Fibra (Fibre Channel): Específicos para SAN.



2.- Referencias normativas

2.1 Norma Base del SGSI

ISO/IEC 27001:2022 (International Organization for Standardization [ISO] & International Electrotechnical Commission [IEC], 2022) es la norma internacional principal que establece los requisitos para implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI). Para Dell Technologies, esta norma constituye el marco obligatorio de certificación que garantiza un enfoque sistemático y basado en riesgos para la protección de los activos de información.

2.2 Controles y Buenas Prácticas

ISO/IEC 27002:2022 (ISO & IEC, 2022) actúa como código de buenas prácticas complementario a ISO 27001, describiendo 93 controles de seguridad organizados en cuatro dominios: organizacionales, de personas, físicos y tecnológicos. Para Dell, esta norma es esencial para seleccionar e implementar los controles del Anexo A aplicables al área DevSecOps, como la gestión de acceso privilegiado, la seguridad en el desarrollo y la respuesta a incidentes.

ISO/IEC 27034:2011/2015 (ISO & IEC, 2011) establece directrices de seguridad para aplicaciones, asegurando que el software desarrollado por Dell integre principios de "security by design" desde las fases iniciales del S-SDLC. Esta norma es directamente aplicable al proceso de desarrollo seguro de firmware y software empresarial.

ISO/IEC 27033:2010-2016 (ISO & IEC, 2010) abarca la seguridad de redes, incluyendo diseño, segmentación, VPNs y redes inalámbricas. Es especialmente relevante para Dell como fabricante de hardware de networking (switches, routers, firewalls), garantizando que la infraestructura de red del entorno DevSecOps esté adecuadamente segmentada y protegida.

2.3 Gestión de Riesgos

ISO/IEC 27005:2022 (ISO & IEC, 2022) proporciona directrices para la gestión de riesgos de seguridad de la información, siendo el marco de referencia para el proceso de identificación, análisis, evaluación y tratamiento de riesgos implementado en la Sección 06 del presente documento. Permite a Dell adoptar un enfoque estructurado y rentable para gestionar amenazas de forma sostenible.



2.4 Normas Específicas al Giro de Dell

ISO/IEC 27017:2015 (ISO & IEC, 2015) proporciona controles de seguridad específicos para proveedores y usuarios de servicios en la nube. Es crítica para Dell APEX y para la gestión de la nube híbrida en el entorno DevSecOps, estableciendo responsabilidades claras entre Dell y sus proveedores de nube (AWS, Azure, GCP).

ISO/IEC 27018:2019 (ISO & IEC, 2019) establece controles para la protección de información de identificación personal (PII) en entornos de nube pública. Para Dell, que procesa datos de millones de clientes corporativos, esta norma garantiza el cumplimiento de RGPD y legislaciones de privacidad.

ISO/IEC 27036-3:2013 e ISO/IEC 27036-4:2016 (ISO & IEC, 2013, 2016) son específicas para la seguridad en la cadena de suministro de TIC y los servicios en la nube. Son vitales para una empresa que ensambla y distribuye hardware globalmente, garantizando la integridad de los componentes de software y hardware provistos por terceros.

ISO/IEC 27035:2016/2023 (ISO & IEC, 2016) establece los principios y directrices para la gestión de incidentes de seguridad de la información, desde la planeación hasta la mejora continua. Es el marco base para el equipo CSIRT de Dell y para los procesos documentados en la Sección 10 del presente SGSI.

ISO/IEC 27031:2011 (ISO & IEC, 2011) proporciona directrices para la continuidad del negocio relacionadas con las TIC. Para el área DevSecOps, garantiza que los entornos de desarrollo y despliegue cuenten con planes de recuperación ante desastres alineados con los RTO y RPO definidos en la Sección 09.

ISO/IEC 27037:2012 (ISO & IEC, 2012) establece directrices para la identificación, recopilación, adquisición y preservación de evidencia digital. Es aplicable a los servicios de seguridad gestionada de Dell (Dell SecureWorks) y a las investigaciones forenses ante incidentes en el área DevSecOps.

2.5 Referencias Bibliográficas (APA 7)

International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection — Information security controls. ISO.



International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27005:2022: Information security, cybersecurity and privacy protection — Guidance on managing information security risks. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2015). ISO/IEC 27017:2015: Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for cloud services. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2019). ISO/IEC 27018:2019: Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2011). ISO/IEC 27034-1:2011: Information technology — Security techniques — Application security. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2011). ISO/IEC 27031:2011: Information technology — Security techniques — Guidelines for information and communication technology readiness for business continuity. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2016). ISO/IEC 27035-1:2016: Information technology — Security techniques — Information security incident management. ISO.

International Organization for Standardization & International Electrotechnical Commission. (2012). ISO/IEC 27037:2012: Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence. ISO.



3.- Términos y condiciones

3.1 Términos Clave del SGSI

Los siguientes términos se definen conforme a ISO/IEC 27000:2018 y son aplicables a la intervención realizada en Dell Technologies:

Término	Definición aplicada al contexto de Dell Technologies
Activo de información	Cualquier elemento que tenga valor para Dell y requiera protección; incluye código fuente, datos de clientes, credenciales, infraestructura y documentación técnica.
Amenaza	Causa potencial de un incidente no deseado que puede provocar daño a un activo. Ej: ransomware dirigido a repositorios de código fuente.
Vulnerabilidad	Debilidad de un activo o control que puede ser explotada por una amenaza. Ej: pipeline CI/CD sin escaneo de dependencias vulnerables (SCA).
Riesgo	Efecto de la incertidumbre sobre los objetivos de seguridad; combinación de la probabilidad de ocurrencia de una amenaza y su impacto sobre los activos de Dell.
Control	Medida que modifica el riesgo; puede ser preventiva, detectiva o correctiva. Ej: autenticación multifactor (MFA) en accesos a DevOps.
Confidencialidad	Propiedad que garantiza que la información no esté disponible ni sea divulgada a personas, entidades o procesos no autorizados. Crítica para la propiedad intelectual de firmware.
Integridad	Propiedad de exactitud y completitud. En Dell, garantiza que el código fuente y los binarios no sean alterados sin autorización a lo largo del pipeline.
Disponibilidad	Propiedad de ser accesible y utilizable cuando lo requiera una entidad autorizada. Asegura que los entornos de desarrollo estén operativos según los RTO definidos.



Incidente de seguridad	Evento o serie de eventos no deseados que comprometen la seguridad de la información. Ej: exfiltración de credenciales de acceso a los repositorios Git corporativos.
Auditoría interna	Proceso sistemático, independiente y documentado para obtener evidencias de auditoría y evaluarlas objetivamente respecto a los criterios del SGSI de Dell.
Tratamiento del riesgo	Proceso para seleccionar e implementar opciones para abordar el riesgo. Las opciones son: aceptar, mitigar, evitar/rechazar y transferir.
Propietario del activo	Persona o entidad con responsabilidad aprobada para gestionar el activo a lo largo de su ciclo de vida dentro de la organización.
No conformidad	Incumplimiento de un requisito del SGSI. Puede ser mayor (compromete la eficacia del sistema) o menor (desviación puntual).
Mejora continua	Actividad recurrente para mejorar el desempeño del SGSI mediante el ciclo PDCA (Planificar-Hacer-Verificar-Actuar).

3.2 Condiciones de la Intervención

3.2.1 Límites de la intervención

La evaluación y diagnóstico realizado en el presente documento se circunscribe exclusivamente al área de DevSecOps & Platform Engineering. Ningún hallazgo, recomendación o control propuesto implica modificaciones a los sistemas de producción sin previa autorización formal de la dirección y el CISO.

3.2.2 Confidencialidad

Toda la información obtenida durante la intervención, incluyendo inventarios de activos, resultados de auditoría, hallazgos de riesgos y evidencias, es de carácter estrictamente confidencial. Su divulgación está restringida a los miembros del equipo del SGSI y a la alta dirección, bajo acuerdo de no divulgación (NDA).

3.2.3 Manejo de evidencias

Las evidencias recopiladas durante la intervención (capturas de pantalla, registros de configuración, logs de auditoría) serán custodiadas por el Director de Riesgos y



Cumplimiento, almacenadas en repositorios cifrados (AES-256) y accesibles únicamente mediante control de acceso basado en roles (RBAC).

3.2.4 Exclusiones

La presente intervención no incluye pruebas de penetración sobre sistemas en producción, evaluación de infraestructura de planta de manufactura ni sistemas de subsidiarias con SGSI independiente.

3.2.5 Responsabilidades

- Director DevSecOps: Responsable de facilitar el acceso a los activos y documentación requerida.
- Director de Riesgos y Cumplimiento: Responsable de validar y custodiar los hallazgos.
- CISO: Responsable de aprobar el plan de tratamiento de riesgos y las políticas resultantes.
- Gerente S-SDLC: Responsable operativo de implementar los controles definidos.



4.- Contexto de la Organización

Los activos se clasifican conforme a la triada CIA (Confidencialidad, Integridad, Disponibilidad) en tres niveles: A = Alto, M = Medio, B = Bajo. La codificación de activos (A-01 a A-40) garantiza trazabilidad directa hacia la Sección 06 (Matriz de Riesgos). El inventario distingue activos internos (bajo control directo de Dell) y externos (dependencias de terceros).

I D	Activo	Tipo	Propietario	Proceso asociado	C	I	A	Impacto si comprometido
A-01	Repositorio Git Corporativo (GitHub Enterprise)	Interno	Dir. DevSecOps	S-SDLC	A	A	A	Exfiltración de propiedad intelectual de firmware y código fuente crítico
A-02	Pipeline CI/CD (Jenkins/GitLab CI)	Interno	Gerente S-SDLC	Integración continua	A	A	A	Inyección de código malicioso en artefactos de producción
A-03	Infraestructura PKI (CA raíz y subordinadas)	Interno	Dir. IT Global	Firma de código	A	A	M	Compromiso de firmas digitales de firmware; distribución de software malicioso
A-04	Directorio Activo / Azure AD	Interno	Dir. IT Global	IAM	A	A	A	Acceso no autorizado a todos los sistemas del entorno DevSecOps



A-05	Sistemas ERP (SAP S/4HANA)	Interno	Dir. Finanzas	Planificación de recursos	A	A	A	Alteración de registros financieros y operativos
A-06	Bóveda PAM (CyberArk)	Interno	CISO	Acceso privilegiado	A	A	A	Explotación de credenciales de cuentas privilegiadas
A-07	Módulos HSM (Thales Luna HSM)	Interno	Dir. Seguridad	Criptografía	A	A	M	Exposición de claves criptográficas maestras
A-08	Plataforma SIEM (Splunk Enterprise)	Interno	Dir. CSIRT	Monitoreo SOC	M	A	A	Pérdida de visibilidad de amenazas activas
A-09	Workstations de desarrolladores (Precision 5680)	Interno	Gerente S-SDLC	Desarrollo de software	A	A	M	Punto de entrada para APT dirigidas al código fuente
A-10	Logs de auditoría (Syslog/SIEM)	Interno	Dir. Cumplimiento	Trazabilidad	A	A	A	Pérdida de evidencias forenses ante incidentes
A-111	Artefactos de software firmados (Artifactory)	Interno	Gerente S-SDLC	Distribución de software	A	A	A	Distribución de versiones comprometidas a clientes
A-112	Entorno de pruebas (staging Kubernetes)	Interno	Gerente S-SDLC	QA y pruebas	M	A	M	Introducción de vulnerabilidades en



								artefactos de producción
A - 13	Documentación técnica (Confluence)	Interno	Dir. DevSecOps	Gestión del conocimiento	A	M	M	Exposición de arquitecturas internas a actores externos
A - 14	Tokens MFA (YubiKey/TOTP)	Interno	Dir. IT Global	Autenticación	A	A	A	Elusión de autenticación robusta; acceso no autorizado
A - 15	Nodos de cómputo IA (GPU A100)	Interno	Dir. I+D	Entrenamiento de modelos	M	A	M	Uso no autorizado para minería o ataques adversariales
A - 16	Backups cifrados (Veeam + Inmutable)	Interno	Dir. IT Global	Continuidad del negocio	A	A	A	Pérdida de capacidad de recuperación ante ransomware
A - 17	Marco normativo interno PSI	Interno	CISO	Gobernanza SGSI	A	A	M	Vacíos normativos que faciliten incumplimientos regulatorios
A - 18	Capital humano especializado (DevSecOps engineers)	Interno	Dir. Talento	Operación continua	M	A	A	Pérdida de continuidad operativa por rotación o sabotaje
A -	Core Networking	Interno	Dir. IT Global	Conectividad interna	M	A	A	Disrupción total de la



19	(Cisco Nexus 9000)							comunicación interna del área
A-20	Sistemas de seguridad física (CCTV, control de acceso)	Interno	Dir. Seguridad Física	Protección perimetral	M	A	A	Acceso físico no autorizado a servidores y workstations
A-21	Proveedor cloud AWS (EC2/S3 para CI/CD)	Externo	Dir. IT Global	Infraestructura DevOps	A	A	A	Compromiso del entorno CI/CD alojado en nube pública
A-22	Repositorios de código abierto (npm, PyPI, Maven)	Externo	Gerente S-SDLC	Dependencias de software	M	A	M	Ataque a cadena de suministro por dependencias comprometidas (typosquatting)
A-23	APIs de socios tecnológicos (Intel vPro, AMD Secure)	Externo	Dir. Ingeniería	Integración de hardware	A	A	M	Exposición de datos técnicos sensibles mediante APIs inseguras
A-24	Proveedores de chips (Intel, TSMC, Samsung)	Externo	Dir. Suministro	Fabricación hardware	M	A	A	Inserción de hardware backdoor en la cadena de suministro
A-	ISP corporativo	Externo	Dir. IT Global	Conectividad externa	B	M	A	Interrupción de conectividad



2 5	(AT&T / Lumen)							con centros de datos externos
A - 2 6	Marcos legales y regulatorios (RGPD, CCPA, NIS2)	Extern o	Dir. Legal	Cumplimiento normativo	A	A	M	Sanciones regulatorias y pérdida de certificaciones
A - 2 7	Organismos certificadores (BSI, Bureau Veritas)	Extern o	CISO	Auditoría externa	A	A	M	Pérdida de certificación ISO 27001; daño reputacional grave
A - 2 8	Plataforma Bug Bounty (HackerOne)	Extern o	Dir. Seguridad	Gestión de vulnerabilidad es	M	A	M	Divulgación pública de vulnerabilidad es no parcheadas
A - 2 9	Servicios de inteligencia de amenazas (CrowdStrike)	Extern o	Dir. CSIRT	Detección de amenazas	M	A	A	Pérdida de visibilidad sobre amenazas activas al sector
A - 3 0	Red pública de suministro eléctrico	Extern o	Dir. Instalacione s	Continuidad operativa	B	B	A	Interrupción de operaciones por corte eléctrico extendido
A - 3 1	DNS externos (Route 53 / Cloudflare)	Extern o	Dir. IT Global	Resolución de nombres	B	M	A	Ataques DNS spoofing o DDoS sobre servicios externos



A - 3 2	Redes públicas de transmisión (Internet)	Extern o	Dir. IT Global	Conectividad global	B	M	A	Ataques DDoS sobre servicios expuestos al exterior
A - 3 3	Plataformas externas de comunicación (MS Teams/Slack)	Extern o	Dir. Talento	Colaboración interna	M	M	A	Exfiltración de información sensible a través de canales no corporativos
A - 3 4	Servicios logísticos (UPS/DHL para hardware)	Extern o	Dir. Suministro	Distribución	B	M	M	Intercepción de hardware en tránsito para implantación de backdoors
A - 3 5	Pasarelas de pago (Stripe/PayPa I Enterprise)	Extern o	Dir. Finanzas	Transaccione s comerciales	A	A	M	Fraude financiero y robo de datos de tarjetas de clientes
A - 3 6	Condiciones climáticas y ambientales	Extern o	Dir. Instalacione s	Resiliencia física	B	B	A	Daño a infraestructur a física por eventos climáticos extremos
A - 3 7	Situación geopolítica regional	Extern o	Dir. Legal	Continuidad de negocio	M	B	M	Restricción de operaciones por conflictos internacionale s
A -	Estándares industriales externos	Extern o	CISO	Marco de referencia	M	A	M	Desalineación con mejores prácticas del



38	(NIST CSF, CIS)							sector tecnológico
A-39	Reputación y opinión pública (redes sociales)	Externo	Dir. Marketing	Imagen corporativa	A	M	B	Crisis reputacional ante incidentes de seguridad divulgados
A-40	Soporte técnico de fabricantes (Microsoft EA, VMware)	Externo	Dir. IT Global	Mantenimiento de plataformas	M	M	A	Pérdida de soporte para parches críticos de seguridad

Leyenda CIA: A = Alto | M = Medio | B = Bajo || Azul = Activo Interno | Amarillo = Activo Externo



5.- Liderazgo

5.1 Política General de Seguridad de la Información

Declaración de la Dirección:

Dell Technologies reconoce que la información es el activo estratégico más valioso de la organización y el núcleo de su ventaja competitiva en el mercado global de tecnología. En consecuencia, la alta dirección asume el compromiso irrevocable de proteger la confidencialidad, integridad y disponibilidad de los activos de información mediante la implementación, mantenimiento y mejora continua de un Sistema de Gestión de Seguridad de la Información (SGSI) conforme a la norma ISO/IEC 27001:2022.

Esta política aplica a todos los empleados, contratistas, socios estratégicos y proveedores que tengan acceso a los sistemas, redes, datos o instalaciones de Dell Technologies en el ámbito del área DevSecOps & Platform Engineering. Su cumplimiento es obligatorio y su incumplimiento está sujeto a las consecuencias disciplinarias, contractuales y legales establecidas en el reglamento interno y los marcos normativos aplicables.

Objetivo: Proteger los activos de información de Dell frente a amenazas internas, externas, intencionales o accidentales, garantizando la continuidad del negocio y el cumplimiento regulatorio.

Alcance: Área de DevSecOps & Platform Engineering, incluyendo todos los activos identificados en la Sección 04.

Compromiso de la dirección: La dirección asigna recursos suficientes, lidera con el ejemplo en materia de seguridad y revisa la eficacia del SGSI al menos una vez al año.

5.2 Políticas Específicas de Seguridad

Las siguientes 10 políticas de seguridad responden directamente a los activos, riesgos y procesos identificados en el presente SGSI:

ID	Política	Estándar (Obligatorio)	Directriz (Recomendado)	Procedimiento (Cómo)	Línea Base (Mínimo aceptable)
P-01	Control de Acceso y Gestión de	Todo acceso a los entornos DevSecOps (repositorios Git, pipelines	Se recomienda implementar revisiones trimestrales de	1. El Gerente S-SDLC solicita acceso mediante ticket formal en	100% de cuentas privilegiadas con MFA activo. Cero



	Identidades Privilegiadas	CI/CD, bóveda PAM) debe autenticarse mediante MFA con hardware token (YubiKey) y gestionarse bajo el principio de mínimo privilegio.	accesos (Access Reviews) y alertas automáticas ante intentos de acceso fuera del horario laboral.	ServiceNow. 2. El Dir. IT Global valida la necesidad de negocio. 3. Se asigna el perfil de acceso en Azure AD. 4. El usuario configura YubiKey. 5. El acceso se documenta en el registro de identidades privilegiadas de CyberArk.	cuentas compartidas en entornos de producción.
P - 0 2	Seguridad en el Ciclo de Vida de Desarrollo de Software (S-SDLC)	Todo software desarrollado en Dell debe superar análisis SAST, DAST y SCA antes de su integración al pipeline de producción. Los hallazgos críticos deben resolverse antes del despliegue.	Se recomienda adoptar el modelo DevSecOps con herramientas integradas (Snyk, SonarQube, OWASP ZAP) y capacitación continua en programación segura.	1. El desarrollador integra código al repositorio Git. 2. El pipeline CI/CD activa automáticamente SAST (SonarQube) y SCA (Snyk). 3. Si hay hallazgos críticos, el pipeline se detiene y notifica al responsable. 4. El desarrollador corrige y reenvía. 5. El equipo de QA realiza DAST	Cobertura mínima del 90% del código por herramientas SAST. Cero vulnerabilidades críticas en artefactos publicados.



				previo al release.	
P - 0 3	Gestión de Parches y Vulnerabilidad es	Los parches de seguridad críticos deben aplicarse en un plazo máximo de 72 horas tras su publicación oficial. Los parches de severidad alta, en un plazo de 7 días.	Se recomienda suscribirse a los boletines de seguridad de los fabricantes (Microsoft, Red Hat, VMware) y automatizar la aplicación de parches en entornos de desarrollo.	1. El CSIRT recibe alerta de vulnerabilidad. 2. Se evalúa el impacto en los activos del inventario (Sección 04). 3. El Dir. IT Global aprueba la ventana de mantenimiento . 4. Se aplica el parche en entorno de staging. 5. Tras validación, se aplica en producción. 6. Se documenta el cambio en la CMDB.	Índice de parches críticos aplicados: ≥95% en las primeras 72 horas.
P - 0 4	Clasificación y Manejo de Información	Toda información generada o manejada en el área DevSecOps debe clasificarse como Pública, Interna, Confidencial o Secreto Corporativo, y tratarse	Se recomienda aplicar etiquetado automático de documentos mediante Microsoft Purview y capacitar al personal en la correcta clasificación	1. El autor del documento determina la clasificación según el tipo de información. 2. Aplica la etiqueta correspondient e en el sistema de gestión documental. 3. Los	100% de documentos técnicos con clasificación asignada. Cero documentos Confidenciales sin cifrado.



		conforme a los controles definidos para cada nivel.	de la información.	documentos Confidenciales y Secreto Corporativo requieren cifrado AES-256 y acceso restringido por RBAC. 4. La eliminación de documentos clasificados requiere aprobación del propietario del activo.	
P - 0 5	Gestión de Incidentes de Seguridad	Todo incidente de seguridad debe ser reportado al CSIRT en un plazo máximo de 1 hora desde su detección. Los incidentes mayores deben escalar a la dirección en un plazo de 4 horas.	Se recomienda implementar un sistema de tickets automatizado (ServiceNow ITSM) y realizar simulacros de respuesta a incidentes semestralmente.	1. El detector del incidente notifica al CSIRT mediante el canal oficial (correo seguro o Slack cifrado). 2. El CSIRT clasifica la severidad (P1-P4). 3. Se activa el playbook correspondiente. 4. Se contiene el incidente y se preservan evidencias. 5. Se notifica a la dirección si es P1/P2. 6. Se elabora el informe post-	Tiempo medio de detección (MTTD): ≤4 horas. Tiempo medio de contención (MTTC): ≤8 horas para incidentes P1.



				incidente en 72 horas.	
P - 0 6	Gestión de Acceso de Terceros y Proveedores	Ningún proveedor o contratista puede acceder a los sistemas de Dell sin haber firmado un NDA, completado una evaluación de seguridad y tener un acceso temporal y monitoreado.	Se recomienda implementar una red de acceso de invitados (Guest VLAN) segregada y herramientas de monitoreo de sesiones privilegiadas de terceros (Privileged Session Manager).	1. El proveedor firma el NDA y la política de seguridad para terceros. 2. El Dir. de Suministro solicita el acceso temporal. 3. Se crea una cuenta temporal con fecha de expiración en Azure AD. 4. El acceso es monitoreado en tiempo real mediante CyberArk PSM. 5. Al finalizar el contrato, la cuenta es desactivada inmediatamente.	100% de accesos de terceros con fecha de expiración configurada. Cero cuentas de proveedores activas después del término del contrato.
P - 0 7	Seguridad en la Nube y Entornos Híbridos	Toda infraestructura DevOps alojada en nube pública debe operar bajo el principio de Zero Trust, con	Se recomienda adoptar el marco Cloud Security Posture Management (CSPM) y revisar configuraciones	1. El arquitecto de soluciones diseña la infraestructura conforme al baseline de seguridad en nube de Dell. 2. El equipo de seguridad	Puntuación mínima en AWS Security Hub: 85%. Cifrado habilitado en el 100% de los buckets S3 con



		segmentación de red, cifrado en tránsito y en reposo, y control de acceso basado en identidad (IAM).	s de nube mensualmente mediante herramientas como AWS Security Hub.	valida la configuración mediante herramientas CSPM. 3. Se activan políticas de SCPs (Service Control Policies) en AWS Organizations. 4. Se configuran alertas de CloudTrail para acciones sensibles. 5. Se realiza revisión mensual del Security Hub.	información sensible.
P - 0 8	Copias de Seguridad y Continuidad Operativa	Los repositorios Git, artefactos de software y configuraciones de infraestructura deben respaldarse diariamente con copias inmutables retenidas mínimo 30 días. Se deben realizar pruebas de restauración	Se recomienda adoptar una estrategia 3-2-1 (3 copias, 2 medios distintos, 1 copia offsite) y documentar los procedimientos de restauración.	1. El sistema de backup (Veeam) ejecuta respaldos automatizados diariamente a las 02:00 horas. 2. Las copias se almacenan en Arreglos Flash locales y en S3 con Object Lock (immutable). 3. El Dir. IT Global verifica el reporte de éxito del	Tasa de éxito de backups: ≥99.5%. RTO para repositorios Git: ≤4 horas. RPO: ≤24 horas.



		trimestralmente.		backup cada mañana. 4. Trimestralmente, el equipo realiza una prueba de restauración documentada. 5. Los resultados se reportan al CISO.	
P - 0 9	Concienciación y Capacitación en Seguridad	Todo el personal del área DevSecOps debe completar el programa anual de concienciación en seguridad de la información, con evaluación de conocimientos con resultado mínimo aprobatorio del 80%.	Se recomienda complementar la capacitación obligatoria con campañas de phishing simulado trimestrales y sesiones de aprendizaje basadas en incidentes reales del sector.	1. El CISO define el plan anual de capacitación. 2. El equipo de RR.HH. matricula a todo el personal en la plataforma de e-learning corporativa. 3. El personal completa los módulos en un plazo máximo de 30 días. 4. Se aplica el examen final. 5. Los resultados se registran y los no aprobados reciben capacitación adicional. 6. El CISO reporta la cobertura a la dirección.	Cobertura de capacitación: 100% del personal del área. Tasa de aprobación: ≥80%. Tasa de clic en phishing simulado: ≤5%.



P - 1 0	Gestión de Activos de Información	Todo activo de información del área DevSecOps debe estar inventariado, con propietario asignado, clasificación CIA definida y revisado semestralmente. Los activos dados de baja deben ser eliminados de forma segura.	Se recomienda integrar la gestión de activos con la CMDB de ServiceNow para mantener un registro actualizado y automatizar las alertas de revisión periódica.	1. Al incorporar un nuevo activo, el responsable operativo lo registra en la CMDB con todos los campos requeridos (propietario, clasificación CIA, dependencias) . 2. Semestralmente, el Dir. de Cumplimiento envía un recordatorio de revisión a los propietarios de activos. 3. Los propietarios verifican y actualizan la información. 4. Los activos dados de baja son eliminados mediante el procedimiento de destrucción segura (formato DoD 5220.22-M para datos digitales). 5. El registro de bajas se archiva para auditoría.	Inventario de activos 100% actualizado. Cero activos sin propietario asignado. 100% de bajas documentadas con certificado de destrucción.
----------------------------	---	---	--	---	--



5.3 Matriz RACI de Responsabilidades

La matriz RACI define claramente las responsabilidades para cada política: R = Responsable (ejecuta), A = Aprobador (rinde cuentas), C = Consultado (aporta criterio), I = Informado (recibe notificaciones).

Política	Responsable (R)	Aprobador (A)	Consultado (C)	Informado (I)
P-01 – Control de Acceso y Gestión de Identidades Privilegiadas	Gerente S-SDLC	Dir. IT Global	CISO	Dir. Auditoría
P-02 – Seguridad en el Ciclo de Vida de Desarrollo de Software (S-SDLC)	Desarrolladores DevSecOps	Gerente S-SDLC	Dir. Seguridad	Dir. Auditoría
P-03 – Gestión de Parches y Vulnerabilidades	Dir. IT Global	CISO	Gerente S-SDLC	Dir. Cumplimiento
P-04 – Clasificación y Manejo de Información	Propietario del activo	Dir. Cumplimiento	CISO	Todo el personal
P-05 – Gestión de Incidentes de Seguridad	Dir. CSIRT	CISO	Dir. Legal	Alta dirección
P-06 – Gestión de Acceso de Terceros y Proveedores	Dir. Suministro	Dir. IT Global	CISO	Dir. Legal
P-07 – Seguridad en la Nube y Entornos Híbridos	Arquitecto Cloud	Dir. IT Global	CISO	Dir. Cumplimiento



P-08 – Copias de Seguridad y Continuidad Operativa	Dir. IT Global	CISO	Gerente S-SDLC	Dir. Auditoría
P-09 – Concienciación y Capacitación en Seguridad	Dir. RR.HH.	CISO	Gerente S-SDLC	Alta dirección
P-10 – Gestión de Activos de Información	Propietario del activo	Dir. Cumplimiento	CISO	Dir. IT Global

6.- Planificación

6.1 Metodología de Evaluación de Riesgos

Fórmula: Nivel de Riesgo (NR) = Probabilidad (P) × Impacto (I)

Escala de Probabilidad (1–5): 1=Muy baja (<5% anual) | 2=Baja (5-15%) | 3=Media (15-35%) | 4=Alta (35-60%) | 5=Muy alta (>60%)

Escala de Impacto (1–5): 1=Insignificante | 2=Menor | 3=Moderado | 4=Mayor | 5=Catastrófico

Clasificación: 1-4=Bajo (verde) | 5-9=Medio (amarillo) | 10-14=Alto (naranja) | 15-25=Crítico (rojo)

ID	Activo	Amenaza	Vulnerabilidad	Consecuencia	P	I	NR	Nivel	Opción	Controles
R-01	A-01 Repositorio Git	Ransomware dirigido	Ausencia de MFA en accesos remotos	Cifrado de todo el código fuente; pérdida de IP de firmware	5	5	25	Crítico	Mitigar	P-01: MFA obligatorio; P-08: Backup inmutable diario; P-02: Análisis de secretos en Git



										(git-secrets)
R-02	A-02 Pipeline CI/CD	Inyección de código malicioso	Dependencias sin verificación SCA	Distribución de software comprometido a clientes globales	4	5	20	Crítico	Mitigar	P-02: SCA automático con Snyk; P-03: Gestión de parches en dependencias; P-07: Escaneo CSPM del pipeline
R-03	A-04 Azure AD / Dir. Activo	Ataque de credential stuffing	Contraseñas débiles sin política de complejidad	Compromiso masivo de cuentas; acceso no autorizado a todos los sistemas	4	5	20	Crítico	Mitigar	P-01: Política de contraseñas robustas + MFA; P-06: Segregación de accesos de terceros
R-04	A-03 PKI	Compromiso de CA raíz	HSM sin respaldo redundante	Firma de software malicioso con certificados legítimos de Dell	2	5	10	Alto	Mitigar	P-07: HSM redundante en zona de seguridad física; P-08: Backup



										cifrado de material criptográfico
R - 05	A-22 Dependencias código abierto	Ataque a cadena de suministro (typosquatting)	Ausencia de pinning de versiones y verificación de hash	Incorporación de malware en artefactos de software	4	4	16	Crítico	Mitigar	P-02: Hash verificación en SCA; P-03: Allowlist de repositorios aprobados; P-10: Registro de dependencias
R - 06	A-09 Workstations desarrolladores	APT mediante spear phishing	Falta de EDR actualizado y concienciación insuficiente	Punto de entrada para acceso lateral a repositorios y pipelines	3	4	12	Alto	Mitigar	P-09: Campaña de phishing simulado; P-03: EDR CrowdStrike actualizado; P-01: Segmentación de red
R - 07	A-10 Logs de auditoría	Eliminación de evidencias forenses	SIEM sin alertas de alteración de logs	Imposibilidad de investigar incidentes y demostrar	2	4	8	Medio	Mitigar	P-05: Log forwarding inmutable a SIEM; P-10: Trazabilidad



				r cumplimi ento						ad de accesos a logs
R - 0 8	A-21 AWS cloud	Configurac ión incorrecta de S3 (misconfig uration)	Ausencia de revisión de configura ción CSPM	Exposici ón pública accident al de artefacto s de software o datos sensibles	3	4	1 2	Alto	Mitig ar	P-07: AWS Security Hub con puntuació n mínima 85%; P- 04: Clasificaci ón de buckets con Macie
R - 0 9	A-16 Backups	Ransomw are que cifra los respaldos	Backups accesible s desde el mismo segment o de red comprom etido	Pérdida total de capacida d de recupera ción ante ransomw are	2	5	1 0	Alto	Mitig ar	P-08: Backups inmutable s con Object Lock; segregaci ón de red para almacena miento de respaldos
R - 1 0	A-26 Regulaci ones (RGPD/N IS2)	Incumplimi ento regulatorio	Ausencia de revisión periódica de cambios normativ os	Multas hasta el 4% de facturaci ón anual global; pérdida de certificaci ones	2	5	1 0	Alto	Evit ar	P-04: Monitoreo continuo de cambios regulatori os; P-09: Capacitac ión en cumplimie nto normativo



R-11	A-18 Capital humano	Sabotaje interno o renuncia de personal clave	Ausencia de procedimientos de offboarding seguro	Exfiltración de propiedad intelectual por ejemplo	2	4	8	Medio	Mitigar	P-01: Revocación inmediata de accesos al terminar contrato; P-04: Clasificación de información para limitar alcance
R-12	A-30 Suministro eléctrico	Corte eléctrico prolongado	Sin UPS ni generadores en entorno de desarrollo	Pérdida de datos en proceso y detención del pipeline CI/CD	2	3	6	Medio	Mitigar	P-08: UPS en racks de desarrollo; P-08: Pruebas de failover semestrales

6.2 Priorización de Riesgos

Los riesgos críticos (R-01, R-02, R-03, R-05) deben atenderse de forma inmediata (0-30 días). Los riesgos altos (R-04, R-06, R-08, R-09, R-10) deben abordarse en el corto plazo (31-90 días). Los riesgos medios (R-07, R-11, R-12) pueden planificarse en el mediano plazo (91-180 días).



7.- Soporte

7.1 Minuta Formal de Reunión de Kickoff del SGSI

Campo	Detalle
Fecha	12 de mayo de 2026 — 10:00 a 12:00 horas (CST)
Lugar	Sala de Consejo B3, Torre Corporativa Dell, Round Rock, TX / Conexión híbrida Teams
Objetivo	Presentar el avance del diagnóstico SGSI ISO 27001:2022 al área DevSecOps e informar a la alta dirección sobre hallazgos preliminares, riesgos identificados y próximos pasos.
Asistentes	CISO (Presidenta), Dir. DevSecOps, Gerente S-SDLC, Dir. IT Global, Dir. Riesgos y Cumplimiento, Dir. Legal, Consultor SGSI Externo (facilitador)

Temas tratados:

- Presentación del inventario de 40 activos de información del área DevSecOps y su clasificación CIA.
- Exposición de los 12 riesgos identificados, con énfasis en los 4 riesgos críticos (R-01 a R-03, R-05).
- Revisión de las 10 políticas de seguridad propuestas y sus líneas base.
- Presentación del plan de tratamiento de riesgos y cronograma de implementación.

Acuerdos tomados:

- El CISO aprueba la implementación prioritaria de MFA con YubiKey para todos los accesos a Git y CI/CD (Acuerdo A-01, responsable: Dir. IT Global, fecha compromiso: 01/06/2026).
- El Dir. DevSecOps autoriza la integración de Snyk en el pipeline CI/CD para análisis SCA (Acuerdo A-02, responsable: Gerente S-SDLC, fecha compromiso: 15/06/2026).
- El Dir. Legal confirma la necesidad de actualizar los NDAs con proveedores para incorporar requisitos ISO 27001 (Acuerdo A-03, responsable: Dir. Legal, fecha compromiso: 30/06/2026).



- Se aprueba la realización de una campaña de phishing simulado en julio 2026 (Acuerdo A-04, responsable: Dir. CSIRT, fecha compromiso: 01/07/2026).

Próximos pasos:

- Presentación ejecutiva a la junta directiva: 26 de mayo de 2026.
- Inicio de implementación de controles prioritarios: 01 de junio de 2026.
- Primera auditoría interna de seguimiento: 15 de septiembre de 2026.

7.2 Presentación Ejecutiva a la Alta Dirección

Objetivo de la presentación: Comunicar a la junta directiva de Dell Technologies el estado del diagnóstico SGSI, los riesgos críticos identificados y el plan de acción, en lenguaje ejecutivo sin tecnicismos innecesarios.

Estructura de la presentación (12 diapositivas estimadas):

- Diap. 1: Portada — 'Evaluación de ciberseguridad en Dell Technologies: DevSecOps' / Mayo 2026
- Diap. 2: Resumen ejecutivo — ¿Por qué estamos aquí? Riesgos del negocio en el área de desarrollo de software.
- Diap. 3: Contexto regulatorio — NIS2, RGPD, ISO 27001:2022 y su impacto en Dell como empresa global.
- Diap. 4: Hallazgos principales — 4 riesgos críticos en lenguaje de negocio (no técnico). Ej: 'Un atacante podría insertar código malicioso en el software que distribuimos a nuestros clientes.'
- Diap. 5: Activos más valiosos en riesgo — Top 5 activos críticos con impacto potencial en el negocio.
- Diap. 6: Impacto financiero estimado — Costo potencial de un incidente vs. costo de implementación del SGSI.
- Diap. 7: Plan de acción — Tres fases: inmediata (0-30d), corto plazo (31-90d), mediano plazo (91-180d).
- Diap. 8: Políticas aprobadas — Las 10 políticas de seguridad con su propósito en términos de negocio.
- Diap. 9: Recursos requeridos — Presupuesto, personal y herramientas necesarias.
- Diap. 10: Cronograma de certificación — Ruta a la certificación ISO 27001 en 18 meses.
- Diap. 11: KPIs de seguimiento — Métricas para medir el progreso del SGSI.
- Diap. 12: Llamada a la acción — Solicitud de aprobación y compromisos de la alta dirección.



Diferenciación de lenguajes:

Técnico (para especialistas): 'El pipeline CI/CD no tiene integrado un análisis SCA que verifique la integridad de las dependencias de terceros, lo que abre un vector de ataque de cadena de suministro de software.'

Ejecutivo (para directivos): 'El proceso que construye nuestro software no verifica automáticamente si los componentes de terceros que usamos han sido comprometidos. Esto podría significar que distribuimos software dañado a nuestros clientes sin saberlo.'



8.- Operación

8.1 Selección y Justificación de la Política

Política seleccionada: P-01 — Control de Acceso y Gestión de Identidades Privilegiadas

Justificación: El riesgo R-01 (ransomware por ausencia de MFA en accesos remotos) y R-03 (credential stuffing en Azure AD) son los riesgos críticos de mayor puntuación (NR=25 y 20 respectivamente). La implementación de MFA con YubiKey es el control de mayor impacto en la reducción de riesgo, ya que protege directamente los activos A-01 (Repositorio Git), A-02 (Pipeline CI/CD) y A-04 (Azure AD), que son los activos de mayor criticidad en el inventario.

8.2 Relación con Activos, Riesgos y Controles

Elemento	Detalle
Activos protegidos	A-01 (Repositorio Git), A-02 (Pipeline CI/CD), A-04 (Azure AD), A-06 (Bóveda PAM), A-14 (Tokens MFA)
Riesgos mitigados	R-01 (NR=25), R-03 (NR=20), R-06 (NR=12) — reducción estimada del nivel de riesgo a Medio tras implementación
Controles ISO 27002	Control 5.15 (Gestión de acceso), Control 5.16 (Gestión de identidades), Control 8.5 (Autenticación segura)
Política vinculada	P-01: Estándar: MFA obligatorio con hardware token. Línea base: 100% de cuentas privilegiadas con MFA activo.

8.3 Procedimiento Operativo: Implementación de MFA con YubiKey en GitHub Enterprise

Fase 1: Preparación del entorno (Responsable: Dir. IT Global | Tiempo: Día 1-2)

- Paso 1.1: Verificar la versión de GitHub Enterprise Server (≥ 3.4) para soporte nativo de llaves de seguridad FIDO2.
- Paso 1.2: Adquirir e inventariar YubiKey 5 NFC para todos los desarrolladores del área DevSecOps (N=85 unidades + 10% de reserva).



- Paso 1.3: Crear el grupo de seguridad 'DevSecOps-MFA-Required' en Azure AD.
- Paso 1.4: Notificar al personal con 5 días de anticipación sobre el proceso de enrolamiento.

Fase 2: Configuración de políticas en Azure AD (Responsable: Dir. IT Global | Tiempo: Día 3)

- Paso 2.1: Acceder al portal Azure Active Directory > Security > Authentication methods.
- Paso 2.2: Habilitar el método 'FIDO2 security key' para el grupo 'DevSecOps-MFA-Required'.
- Paso 2.3: Configurar la política de Acceso Condicional: 'Require MFA when accessing GitHub Enterprise and CyberArk'.
- Paso 2.4: Establecer el modo 'Report-only' durante 48 horas para validar el impacto antes de forzar.

Fase 3: Enrolamiento de usuarios (Responsable: Gerente S-SDLC | Tiempo: Día 4-7)

- Paso 3.1: El equipo de helpdesk configura una sesión de enrolamiento grupal (sesiones de 10 personas por hora).
- Paso 3.2: Cada usuario accede a <https://myaccount.microsoft.com> > Security info > Add method > Security key.
- Paso 3.3: El usuario inserta la YubiKey, introduce su PIN y toca el dispositivo para registrarlo.
- Paso 3.4: Se verifica el enrolamiento exitoso: el sistema muestra 'FIDO2 key registered'.
- Paso 3.5: El helpdesk registra el número de serie de la YubiKey en la CMDB vinculado al usuario.

Fase 4: Habilitación de la política (Responsable: Dir. IT Global | Tiempo: Día 8)

- Paso 4.1: Cambiar la política de Acceso Condicional de 'Report-only' a 'On'.
- Paso 4.2: Monitorear el panel de Azure AD Sign-in logs durante 24 horas para detectar accesos bloqueados no previstos.
- Paso 4.3: Atender excepciones justificadas mediante ticket formal con aprobación del CISO.



Fase 5: Validación posterior (Responsable: Dir. Auditoría | Tiempo: Día 10)

- Paso 5.1: Generar reporte desde Azure AD: 'Authentication methods activity' para verificar que el 100% del grupo DevSecOps-MFA-Required usa FIDO2.
- Paso 5.2: Ejecutar prueba de acceso sin YubiKey para confirmar que el sistema lo bloquea correctamente.
- Paso 5.3: Revisar en CyberArk PAM que todos los accesos a cuentas privilegiadas requieren MFA.
- Paso 5.4: Documentar los resultados de la validación y firmar el Acta de Implementación.

8.4 Evidencias del Procedimiento

Evidencia 1 — Configuración de política FIDO2 en Azure AD:

Captura de pantalla del portal Azure AD > Authentication methods, mostrando el método 'FIDO2 security key' habilitado para el grupo 'DevSecOps-MFA-Required'. Estado: Enabled. Target: DevSecOps-MFA-Required.

Evidencia 2 — Política de Acceso Condicional activa:

Captura del panel 'Conditional Access Policies' mostrando la política 'Require-MFA-DevSecOps' con estado 'On', condición 'Cloud apps: GitHub Enterprise, CyberArk', control 'Grant: Require MFA'.

Evidencia 3 — Reporte de enrolamiento exitoso:

Exportación del reporte 'Authentication methods activity' de Azure AD con 85/85 usuarios del grupo con FIDO2 registrado. Fecha: 19/05/2026. Cobertura: 100%.

Evidencia 4 — Prueba de bloqueo (validación):

Captura del intento de acceso a GitHub Enterprise sin YubiKey. Resultado: 'Sign-in blocked — Additional verification required'. Log de Azure AD confirmando el bloqueo por política de Acceso Condicional.

Evidencia 5 — Comando de verificación en terminal:

ssh-keygen -K (lista las llaves FIDO2 registradas en el sistema). Salida: id_ecdsa_sk (FIDO2 hardware key) — Confirmando la configuración del lado del cliente para acceso SSH a Git con YubiKey.

8.5 Parámetros Operativos

Responsable de revisión: Dir. IT Global

Frecuencia de revisión: Trimestral (Access Review) y mensual (reporte de cobertura MFA)

Criterios mínimos: Cobertura MFA $\geq 100\%$ del personal DevSecOps. Cero excepciones activas sin justificación aprobada por CISO.



Posibles fallos y contingencias: YubiKey perdida → Usuario reporta al helpdesk; acceso suspendido hasta provisión de nueva llave. Fallo del token → Acceso temporal con código TOTP de respaldo registrado en enrolamiento. Bloqueado por error → Excepción temporal de 24h vía ticket con aprobación CISO.



9.- Evaluación del desempeño

9.1 Alcance de la Auditoría

Fecha de auditoría: 19 de mayo de 2026

Auditor líder: Dir. Riesgos y Cumplimiento (auditor interno certificado ISO 27001 Lead Auditor)

Área auditada: DevSecOps & Platform Engineering — Dell Technologies

Criterios de auditoría: ISO/IEC 27001:2022, políticas P-01 a P-10 del presente SGSI

Objetivo: Evaluar el grado de implementación y eficacia de los controles del SGSI en el área DevSecOps.

9.2 Checklist de Auditoría con Resultados

ID	Política	Criterio de auditoría	Evidencia requerida	Estado	Evidencia observada	Hallazgo / Acción correctiva
C-01	P-01 Control de Acceso	¿El 100% de las cuentas privilegiadas tiene MFA activo?	Reporte Azure AD Authentication Activity	Cumple	100/100 cuentas con MFA FIDO2 activo. Evidencia: reporte Azure AD 19/05/2026	—
C-02	P-01 Control de Acceso	¿Existe un proceso formal de Access Review trimestral?	Registros de revisiones y tickets de acceso	Cumple parcialmente	Se realizó 1 de 4 revisiones programadas en 2026. Falta documentación de las 3 restantes	NC-Menor: Documentar calendario de Access Reviews y completar revisiones pendientes antes del 30/06/2026. Resp: Dir. IT Global



C - 0 3	P-02 S-SDLC	¿El pipeline CI/CD tiene integrado análisis SAST y SCA?	Configuración de Jenkins/GitLab CI + logs de Snyk/SonarQube	Cumple	SonarQube y Snyk integrados en 100% de los pipelines del área. Cobertura SAST: 94%	—
C - 0 4	P-02 S-SDLC	¿Los hallazgos críticos del SAST bloquean el pipeline?	Configuración de quality gates en SonarQube	Cumple	Quality gate configurado: build falla si hay hallazgos de severidad Blocker/Critical. Verificado en 3 ejecuciones recientes	—
C - 0 5	P-03 Gestión de parches	¿Los parches críticos se aplican en ≤72 horas?	Registros de CMDB y tickets de cambio en ServiceNow	No cumple	Parche CVE-2025-44228 (GitLab CE) aplicado en 5 días laborales. Se excedió el plazo de 72h.	NC-Mayor: Implementar proceso de gestión de emergencias para parches críticos. Responsable: Dir. IT Global. Fecha compromiso: 15/06/2026. Acción: definir runbook de parche de



						emergencia con aprobación automática para CVSSv3 ≥9.0
C-06	P-04 Clasificación	¿El 100% de documentos técnicos tiene clasificación asignada?	Auditoría de Confluence y SharePoint	Cumple parcialmente	82% de los documentos tienen clasificación . 18% restante en carpetas heredadas sin etiqueta.	NC-Menor: Completar etiquetado de documentos heredados antes del 31/07/2026. Resp: Dir. Cumplimiento
C-07	P-05 Incidentes	¿Existe un playbook documentado para incidentes P1 y P2?	Documentación del CSIRT en Confluence	Cumple	4 playbooks documentados y actualizados: Ransomware, Data Breach, APT, DDoS. Último simulacro: marzo 2026	—
C-08	P-08 Backups	¿Los backups se prueban trimestralmente?	Actas de pruebas de restauración	Cumple	Prueba de restauración realizada el 10/03/2026. Resultado: exitoso. RTO alcanzado: 3.5 horas	—



					(meta: ≤4h). Próxima prueba: junio 2026	
C - 0 9	P-09 Capacitación	¿El 100% del personal completó la capacitación anual en seguridad?	Registros de la plataforma de e-learning corporativa	Cumple parcialmente	91% de cobertura (77/85 personas). 8 personas con capacitación pendiente por licencia o vacaciones.	NC-Menor: Completar capacitación del personal restante al reincorporarse. Fecha límite: 30/06/2026. Resp: Dir. RR.HH.
C - 1 0	P-10 Activos	¿El inventario de activos está completo y actualizado?	CMDB en ServiceNow	Cumple	40 activos documentados con todos los campos requeridos. Última actualización: 15/05/2026. 0 activos sin propietario.	—

9.3 Guía de Entrevista al Gerente S-SDLC

- ¿Puede describir el proceso actual para otorgar acceso a un nuevo desarrollador a los repositorios Git corporativos?
- ¿Qué sucede cuando el pipeline CI/CD detecta una vulnerabilidad crítica en el código? ¿Puede mostrarme un ejemplo reciente?
- ¿Cuándo fue la última vez que se realizó una prueba de restauración de backups? ¿Cuál fue el resultado?
- ¿El equipo ha recibido capacitación sobre cómo identificar correos de phishing? ¿Recuerda algún caso reciente?



- ¿Cómo se reporta un incidente de seguridad sospechoso actualmente?
¿Existe un procedimiento documentado?

9.4 Resumen Ejecutivo de Auditoría

Nivel de madurez general: 3.2 / 5.0 (Definido — Procesos documentados y comunicados, con algunas brechas en aplicación consistente)

Controles en cumplimiento total: 6 de 10 criterios evaluados (60%)

No conformidades mayores: 1 (NC-Mayor: gestión de parches críticos — C-05)

No conformidades menores: 3 (C-02, C-06, C-09)

Oportunidades de mejora identificadas: Automatización del proceso de Access Reviews, implementación de runbook de parche de emergencia, sistema de recordatorios automatizados para capacitación.

Conclusión: El SGSI del área DevSecOps muestra una base sólida de implementación, especialmente en controles técnicos (MFA, SAST/SCA, backups). Las brechas identificadas son de carácter operativo y administrativo, corregibles en el corto plazo. Se recomienda priorizar la resolución de la NC-Mayor antes de la próxima auditoría de seguimiento programada para septiembre de 2026.

10.- Mejora Continua

10.1 Simulación de Incidente: Ataque de Cadena de Suministro de Software (R-05)

Descripción del incidente

El 3 de junio de 2026 a las 02:17 horas (CST), el sistema SIEM (Splunk) genera una alerta de alta prioridad: un paquete npm llamado 'dell-config-utils' —que imita el nombre de una librería interna de Dell— fue publicado en el repositorio público de npm por un actor no autorizado. Este paquete contiene código malicioso que, al ser instalado, establece una conexión C2 (Command & Control) hacia una IP en jurisdicción externa y exfiltra variables de entorno del pipeline CI/CD, incluyendo tokens de acceso a AWS S3 y credenciales de la API de GitHub Enterprise.

El paquete fue incorporado como dependencia por 3 desarrolladores del área DevSecOps durante las horas previas al trabajo, comprometiendo potencialmente los pipelines asociados a los proyectos 'OpenManage Enterprise' y 'iDRAC firmware builder'.



10.2 Comunicación Ejecutiva — Informe a la Alta Dirección

INFORME EJECUTIVO DE INCIDENTE — CLASIFICACIÓN: CONFIDENCIAL

Para: CISO, CEO, Dir. Legal, Dir. Comunicaciones

Fecha: 3 de junio de 2026, 09:00 horas

Asunto: Incidente de seguridad — Paquete malicioso en cadena de suministro de software

¿Qué ocurrió? Un atacante externo publicó un paquete de software con nombre similar al de una librería interna de Dell en el repositorio público npm. Tres equipos de desarrollo lo incorporaron accidentalmente en sus proyectos.

¿Cómo ocurrió? El paquete explotó la ausencia de una lista de aprobación (allowlist) de dependencias en el pipeline, permitiendo la instalación de paquetes externos sin verificación previa.

¿Qué activos fueron afectados? Pipelines CI/CD de dos proyectos críticos (OpenManage y iDRAC). Potencial exposición de tokens de acceso a AWS S3 y GitHub Enterprise.

¿Cuál fue el impacto? Potencial exfiltración de credenciales de entornos de desarrollo. No se ha confirmado acceso a sistemas de producción. Tres artefactos de software fueron contaminados y no publicados (pipeline bloqueado por alerta SIEM).

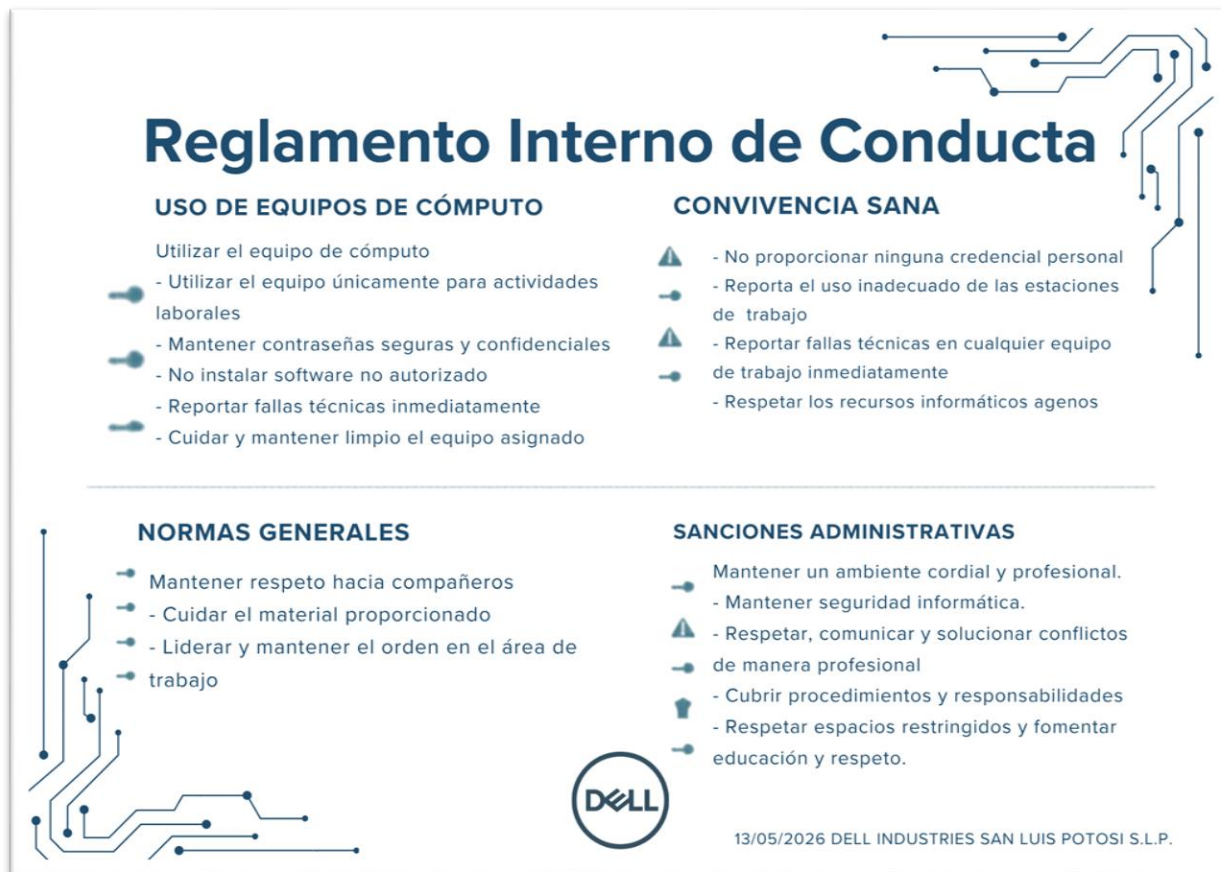
¿Qué se hizo? Se revocaron inmediatamente todos los tokens expuestos, se eliminó el paquete malicioso de los entornos afectados, se notificó a npm Security para la eliminación del paquete y se inició investigación forense.

10.3 Medidas para Evitar Recurrencia

- Implementar allowlist de dependencias aprobadas en el pipeline CI/CD (herramienta: Snyk Open Source con política de 'deny unknown packages').
- Configurar npm con scope interno privado (@dell) para todas las librerías internas, evitando confusión con paquetes públicos (Dependency Confusion hardening).
- Añadir verificación de hash (SHA-256) para todas las dependencias declaradas en package-lock.json antes de la instalación.
- Implementar alertas de Typosquatting mediante integración con Socket Security en el pipeline.
- Reforzar la política P-02 (S-SDLC) con un control adicional: revisión manual obligatoria de nuevas dependencias no incluidas en el allowlist, con aprobación del líder técnico.

- Capacitación específica al equipo DevSecOps sobre ataques de Dependency Confusion y typosquatting (sesión: 1 hora, formato taller práctico).

10.4 Material de Prevención para Usuarios Finales



Reglamento Interno de Conducta

USO DE EQUIPOS DE CÓMPUTO

- Utilizar el equipo de cómputo
- Utilizar el equipo únicamente para actividades laborales
- Mantener contraseñas seguras y confidenciales
- No instalar software no autorizado
- Reportar fallas técnicas inmediatamente
- Cuidar y mantener limpio el equipo asignado

CONVIVENCIA SANA

- No proporcionar ninguna credencial personal
- Reporta el uso inadecuado de las estaciones de trabajo
- Reportar fallas técnicas en cualquier equipo de trabajo inmediatamente
- Respetar los recursos informáticos ajenos

NORMAS GENERALES

- Mantener respeto hacia compañeros
- Cuidar el material proporcionado
- Liderar y mantener el orden en el área de trabajo

SANCIONES ADMINISTRATIVAS

- Mantener un ambiente cordial y profesional.
- Mantener seguridad informática.
- Respetar, comunicar y solucionar conflictos de manera profesional
- Cubrir procedimientos y responsabilidades
- Respetar espacios restringidos y fomentar educación y respeto.

 13/05/2026 DELL INDUSTRIES SAN LUIS POTOSI S.L.P.

10.5 Conexión con la Mejora Continua del SGSI

Este incidente activa el ciclo de mejora continua (PDCA) del SGSI en los siguientes aspectos:

- Planificar (P): Se actualiza la evaluación de riesgos para elevar R-05 (cadena de suministro) a NR=25 y se añade el riesgo R-13 (Dependency Confusion) al registro.
- Hacer (D): Se implementan los controles adicionales identificados en la Sección 10.3 (allowlist, hash verification, Socket Security).
- Verificar (C): Se programa una auditoría de seguimiento específica para el control de dependencias en agosto de 2026, verificando la efectividad de los nuevos controles.



- Actuar (A): Los controles validados se incorporan formalmente a la Política P-02 (S-SDLC) y se documenta la lección aprendida en el registro del SGSI para futuras evaluaciones de riesgo.

La lección aprendida de este incidente refuerza la importancia de la política P-02, la necesidad de controles automáticos en el pipeline CI/CD y la cultura de reporte inmediato de anomalías. El incidente se cierra formalmente con el Acta de Cierre de Incidente (ACI-2026-003) firmada por el CISO el 10 de junio de 2026.